RadioTEDU Mini Player

Güvenlik Testi Raporu

Tarih: 13.10.2026 · İncelenen: `radiotedu-miniplayer.js`, `radiotedu-miniplayer.php` (v1.0.0)

Özet. Kritik bir açık bulunmadı: XSS yok, URL doğrulaması sağlam, PHP tarafı temiz. Ancak yazı içeriğine HTML ekleyebilen bir kullanıcı (WordPress Contributor/Author), mini oynatıcıyı **sahte bir oynatıcıya bağlayabiliyor** ve ziyaretçiyi başka bir siteye yönlendirebiliyor. Raporlanan bulguların tamamı tarayıcıda çalıştırılarak doğrulandı.

Kapsam ve yöntem

- İncelenen JS dosyası, repodaki `radio-tedu-client/src/lib/radiotedu-miniplayer.js` kopyasıyla birebir aynıdır.
- Kod satır satır incelendi (statik analiz).
- URL ve veri doğrulama fonksiyonları Node.js üzerinde yaklaşık 50 kötü niyetli girdiyle test edildi.
- Sahte tema oynatıcı çubuğu, sahte REST uç noktaları ve saldırı içerikleri olan yerel bir test sitesi kuruldu; betik gerçek bir Chromium tarayıcısında çalıştırıldı. Test tarayıcısı gerçek PiP penceresi açamadığı için `documentPictureInPicture.requestWindow` aynı kökenli bir iframe döndürecek şekilde taklit edildi.
- Temanın kendi kodu (`assets/js/app.js`) repoda bulunmadığından incelenemedi.

Bulgular

#	Önem	Bulgu	Durum
1	**Orta**	Sahte `[data-rt-player]` ile oynatıcıyı ele geçirme	Doğrulandı
2	**Düşük–Orta**	Sahte `[data-rt-play="station"]` ile "Sonraki" düğmesinden yönlendirme	Doğrulandı
3	**Düşük**	`__radioteduMiniPlayer` DOM clobbering ile eklentiyi kapatma	Doğrulandı
4	**Düşük**	Sahte `[data-rt-miniplayer-open]` gerçek düğmeyi bastırıyor	Doğrulandı
5	**Düşük**	`RadioTEDUConfig.restBase` DOM clobbering	Doğrulandı (koşullu)
6	**Bilgi**	`stationId = ".."` ile REST yolunda bir üst dizine çıkma	Doğrulandı
7	**Bilgi**	Kapak/yayın adresi herhangi bir https sunucusu olabiliyor; referrer politikası yok	Gizlilik
8	**Bilgi**	Sıkı CSP (`style-src`) altında PiP stilsiz açılır	Uyumluluk

Ortak sebep: WordPress, yazı içeriğinde `id` ve `data-*` özniteliklerine izin verir. Kod ise `document.querySelector(...)` ile sayfadaki **ilk** eşleşmeyi alıyor. Yazı içeriği footer'daki oynatıcı çubuğundan önce geldiği için ilk eşleşme saldırganın öğesi oluyor.

Bulgu detayları

1. Oynatıcıyı ele geçirme [Orta]

`radiotedu-miniplayer.js:83, :719`

- Yazı içeriğine sahte bir `<div data-rt-player>` konuldu.
- Launcher düğmesi sahte çubuğa eklendi. PiP penceresinde "SAHTE BAŞLIK" göründü ve kapak olarak `attacker.example/pixel.gif` yüklendi (izleme pikseli olarak kullanılabilir).
- **Oynat**'a basıldığında sahte toggle'ın `<a href>` öğesi tıklandı; sayfa `https://attacker.example/phish` adresine yönlendiriliyordu.

2. "Sonraki" düğmesinden yönlendirme [Düşük–Orta]

`radiotedu-miniplayer.js:225–228`

- `pageButton.click()` öğenin türünü kontrol etmiyor.
- Hedef istasyonla aynı `data-id`'ye sahip bir `<a>` içeriğe konursa, "Sonraki"ye basınca bu link açılıyor. Testte `https://attacker.example/redirect` adresine yönlendirme oluştu.

3. Eklentiyi kapatma [Düşük]

`radiotedu-miniplayer.js:11`

- İçerikte `<div id="__radioteduMiniPlayer">` bulunduğunda `window.__radioteduMiniPlayer` bu öğeyi gösteriyor ve truthy sayılıyor.
- Betik hemen çıkıyor, launcher düğmesi hiç oluşmuyor.

4. Gerçek düğmeyi bastırma [Düşük]

`radiotedu-miniplayer.js:715–717, :733`

- İçerikte tek bir `<span data-rt-miniplayer-open>` bulunması, gerçek düğmenin eklenmesini engelliyor.
- Sayfadaki herhangi bir öğe bu öznitelikle PiP penceresini açabiliyor.

5. restBase clobbering [Düşük]

`radiotedu-miniplayer.js:89`

- İki adet `<a id="RadioTEDUConfig">` öğesi, `restBase` değerini aynı kökende başka bir yola çevirebiliyor. Testte istekler `/wp-content/uploads/evil/stations` adresine gitti; saldırganın JSON'undaki yayın adresi ve `<img onerror>` içeren başlık temanın click handler'ına ulaştı.
- Sınırlayan koşullar: tema `wp_localize_script` ile `var RadioTEDUConfig` tanımlıyorsa bu yöntem işe yaramaz; ayrıca saldırganın sitede `/stations` ile biten ve kendi kontrol ettiği bir dosyaya ihtiyacı vardır.
- **Temada kontrol edilmeli:** Tema `data-title` / `data-subtitle` değerlerini `innerHTML` ile ekrana basıyorsa bu zincir gerçek bir XSS'e dönüşür.

6. REST yolunda dizin aşımı [Bilgi]

`radiotedu-miniplayer.js:159`

- `encodeURIComponent` noktaları kodlamadığı için `..` değeri isteği `/v1/live` adresine çeviriyor.
- Yalnızca tam olarak `..` işe yarıyor (`../..` kodlanıyor). Etkisi önemsiz.

7. Gizlilik [Bilgi]

`radiotedu-miniplayer.js:65, :208, :551`

- Kapak görselleri ve istasyon yayın adresleri herhangi bir https sunucusundan gelebiliyor; PiP'teki `<img>` için referrer politikası tanımlı değil.

8. CSP uyumluluğu [Bilgi]

`radiotedu-miniplayer.js:483–485`

- PiP penceresi açanın CSP'sini devralır. `style-src 'unsafe-inline'` içermeyen sıkı bir politika altında eklenen `<style>` engellenir ve pencere stilsiz açılır.

Sağlam çıkan kısımlar

- **XSS:** `innerHTML` yalnızca statik şablon ve ikonlarla kullanılıyor; tüm veri `textContent` veya özniteliklerle yazılıyor.
- **safeUrl engelledikleri:** `javascript:` (büyük/küçük harf, boşluk ve tab varyantları), `data:`, `vbscript:`, `blob:`, `file:`, başka sitelere `http:`.
- **Spotify/Amazon allowlist reddettikleri:** `open.spotify.com.evil.com`, `open.spotify.com@evil.com`, `amazon.evil.com`, `evilamazon.com`, `www.www.amazon.com`, punycode ve Kiril harfli taklitler, sonda nokta olan

alan adları.

- **Linkler:** `rel="noopener noreferrer"` kullanılıyor.
- **REST:** Başka köke istek gönderilemiyor; 8 sn zaman aşımı ve üst üste istekleri engelleyen kilit var.
- **Diğer:** Seçici (selector) enjeksiyonu yok, renk doğrulaması sağlam, harici bağımlılık yok.
- **PHP:** `ABSPATH` kontrolü var, kullanıcı girdisi yok, nonce veya kaçışlama gerektiren işlem yok. Sorun bulunmadı.

Önerilen düzeltmeler

```
// [3] Symbol ile tanımlanan bayrak DOM clobbering ile ezilemez
const FLAG = Symbol.for('radiotedu.miniplayer');
if (window[FLAG]) return;
window[FLAG] = true;

// [5] Yalnızca gerçek string değerleri kabul et (clobber edilmiş <a> reddedilir)
const cfg = window.RadioTEDUConfig;
const rawBase = typeof cfg?.restBase === 'string' ? cfg.restBase : '/wp-json/radiotedu/v1/';
// aynısını language için de uygula

// [1] + [4] Oynatıcıyı benzersiz bir id ile seç, içerikteki kopyaları yok say
const player = document.getElementById('rt-player'); // temadaki gerçek id
if (!player?.matches('[data-rt-player]')) return null;
// toggle'ın gerçekten <button> olduğunu doğrula;
// launcher'ları ve click tetikleyicisini yalnızca player içinde ara

// [2] Sayfadaki öğeye dokunma; her zaman kendi gizli düğmeni oluştur
// (ya da en azından: node.tagName === 'BUTTON' && node.closest('[data-rt-player], .rt-stations'))

// [6] İstasyon kimliğini doğrula
if (!/^[a-z0-9_-]+$/i.test(s.stationId)) return;

// [7] Kapak isteklerinde referrer gönderme
el.art.referrerPolicy = 'no-referrer';
```

Öncelik: önce 1 ve 2 (yönlendirme riski), ardından temanın `data-title` işleyişinin kontrolü (5), sonra 3–4 ve 6–7.